

Segurança de Dados



história da Criptografia

A criptografia pode ser definida como o método pelo qual a informação é convertida em um código secreto que tem como objetivo ocultar o verdadeiro significado da informação. Sua origem remonta a cerca de 100 a.C. e, atualmente o uso da criptografia é essencial para garantir a proteção das comunicações, informações e de diversas outras tecnologias, sistemas, serviços e recursos utilizados na rede mundial de computadores – Internet, para garantir a segurança da informação e a segurança cibernética.

Na tecnologia da informação os dados não criptografados são conhecidos como texto simples e os dados criptografados são denominados de texto cifrado. As fórmulas utilizadas para codificar e decodificar um dado ou informação são conhecidas como algoritmos de criptografia ou cifras.

Na história, a “Cifra de César” é um dos primeiros registros documentados sobre a utilização da criptografia para codificar e proteger mensagens. No qual o imperador romano Júlio César utilizava a criptografia para enviar mensagens secretas aos seus generais que estavam em campo, expandindo o império romano, dando uma grande vantagem estratégica.

O método utilizado na Cifra de César, consiste no deslocamento de cada letra da mensagem em três letras para a direita, transformando o texto simples em texto cifrado. Assim, caso a mensagem fosse interceptada pelo inimigo, ele por sua vez, não conseguiria compreender a mensagem. Para entender melhor o método de cifragem, por exemplo: cada letra “A” contida no texto original enviado por Júlio César, é substituída por três letras a direita, no caso a letra “A” passa a ser a letra “D”, a letra “B” passa a ser a letra “E”, a letra “C” se transforma na letra “F” e, assim por diante. Esse tipo de cifra, também, pode ser denominado de “cifra de deslocamento”.

Observa-se que o algoritmo utilizado por Júlio César para cifrar as mensagens era o “3” (três). Atualmente o uso moderno da “Cifra de César” é um código denominado de “ROT13” que se trata da abreviação de “rotate by 13 places” ou “deslocamento para

13 espaços”, sendo utilizado em diversos fóruns online para codificar informações como spoiler de filmes, jogos ou qualquer outro tipo de mensagem.

Outro exemplo histórico do uso da criptografia deu-se no século XVI, a “Cifra de Vigenère”, que utilizava uma chave secreta para codificar a mensagem. Neste modelo, o criador do código escolhe de forma aleatória qualquer palavra ou combinação de letras para ser utilizado como “chave” de criptografia.

Ambos os métodos de criptografia “Cifra de César” e “Cifra de Vigenère” são exemplos pioneiros da utilização da criptografia como método para “ocultar” o verdadeiro significado de uma informação ou mensagem e, foram considerados os primeiros métodos de proteger dados e informações durante o processo de comunicação, tornando assim a comunicação entre 2 ou mais partes confidenciais.

Durante a II Guerra Mundial a criptografia exerceu um papel estratégico. Um dos fatos mais relevantes e famosos do uso da criptografia como arma de guerra, foi a máquina Enigma desenvolvida por Arthur Scherbius em 1918.

A Enigma usava um conjunto de mecanismos rotores que embaralhavam o alfabeto para transformar de maneira rápida e fácil qualquer texto simples em um texto cifrado e/ou vice-versa, tornando-se uma tecnologia essencial para o comando central do exército alemão nazista, realizasse a troca de mensagens codificadas entre seus generais e tropas no front durante toda a II Guerra Mundial.

Além da máquina Enigma, houve outros fatos que marcaram a história, tais como: a criação do DES – Data Encryption Standard, um algoritmo de criptografia criado pelo governo americano que utilizava uma “chave simétrica” para realizar a codificação e decodificação de dados, informações e mensagens e, o desenvolvimento da criptografia assimétrica.

Até o início da década de 70 o uso das tecnologias de criptografia era exclusivo e restrito ao meio militar. Porém, em 1971 surgiram publicações no meio científico sobre o uso dos primeiros algoritmos de criptografia voltados para o setor privado. Tais publicações despertaram o interesse de empresas que desejam manter sua propriedade intelectual e suas informações protegidas e seguras.

Entre as primeiras publicações voltadas para o setor privado, um conjunto de algoritmos de criptografia desenvolvido pela IBM, batizado de “Lúcifer” ganhou

destaque, tornando-se um padrão de criptografia de dados utilizado em várias empresas norte-americanas após algumas modificações realizadas pela Agência de Segurança Nacional – NSA do governo norte-americano que posteriormente ficou conhecido como o padrão de criptografia “DES”.

É importante ressaltar que até o início do século XX todos os modelos de criptografia conhecidos utilizavam algoritmos de criptografia simétricos. Neste modelo, o emissor e o receptor da mensagem usavam uma única “chave privada” e “idêntica” para codificar e decodificar a informação. Isto significa que ambas as partes precisavam ter em “mãos” essa chave para criptografar e descriptografar os dados ou informações contidas na mensagem.

Neste contexto a empresa ou usuário que utilizasse o modelo de criptografia simétrico, era obrigado a realizar uma configuração de um canal seguro para transmitir a chave de criptografia antes mesmo de realizar a própria criptografia da mensagem, o que tornava o uso da criptografia alto, em termos de investimentos, custos operacionais com comunicação e recursos, o que fez surgir um novo formato a criptografia assimétrica.

Criptografia Simétrica e Assimétrica

Como comentado anteriormente, a criptografia simétrica é um método de codificação e decodificação de dados e informações que tem como base central a utilização de um algoritmo de chaves privadas. Ou seja, a utilização de uma única “chave secreta” por ambas as partes para codificar ou decodificar o dado ou a informação. Basicamente, a chave secreta é usada para transformar um texto simples para um texto cifrado.

A criptografia simétrica é uma das técnicas de cifragem mais utilizadas, sendo empregada na proteção de dados e informações confidenciais. Seu funcionamento consiste em uma cifra de fluxo ou cifra de blocos para criptografar e descriptografar dados. Na cifra de fluxo, cada um dos bytes é cifrado de forma individual, ou seja, um a um. Já na cifra de blocos, há a conversão de uma unidade inteira de bytes ou blocos de bytes de texto simples para texto cifrado, usando um comprimento de chave predeterminado que pode estar entre 128, 192 ou 256 bits.

É importante lembrar que tanto o remetente quanto o destinatário precisam conhecer a “chave secreta” para codificar e decodificar os dados e informações na criptografia simétrica. Caso contrário não conseguirão! Por esse motivo deve-se haver um cuidado maior com a proteção dessa chave.

Um exemplo simplificado do uso da criptografia simétrica pode ser entendido dessa forma: João é o remetente de um documento em PDF confidencial e, deseja enviar a Maria que é a destinatária desse documento confidencial. Neste caso, João utilizaria a chave secreta que possui para criptografar o arquivo PDF e enviá-lo para Maria. Para a Maria conseguir ler esse documento, precisará ter em mãos a mesma chave secreta que o João possui e utilizou para cifrar o documento, caso contrário não conseguirá! Neste contexto, João deverá compartilhar a mesma chave secreta com Maria. Este processo de criptografia pode ser realizado manualmente ou automaticamente entre ambas as partes (João e Maria).

São exemplos de criptografia simétrica: (a) o padrão de criptografia de dados DES; (b) o padrão de criptografia de dados Triplo DES; © o padrão de criptografia avançada de dados AES; (d) o algoritmo internacional de criptografia de dados IDEA e os protocolos TLS/SSL utilizados na camada de aplicação do modelo de arquitetura TCP/IP.

Como vantagens podemos citar: (a) rapidez na implementação; (b) facilidade de uso e; © adoção e aceitação da indústria. Já como principal desvantagem podemos citar: o uso e compartilhamento de uma única chave secreta para cifrar e decifrar o dado ou informação. Mas, por quê? Bem, porque caso essa chave secreta seja armazenada em um local inseguro, ou seja, capturada por indivíduos mal-intencionados ou criminosos cibernéticos, eles por sua vez poderão facilmente decodificar o dado ou a informação e, assim quebrar o princípio da confidencialidade.

De lado oposto temos a criptografia assimétrica que ao invés de utilizar uma única chave privada (secreta) para criptografar e descriptografar dados e informações confidenciais, a criptografia assimétrica utiliza pares de chaves privadas e públicas para codificar e decodificar o dado e/ou a informação o que a torna diferente da criptografia simétrica.

Para entender melhor o conceito de pares de chave privada e chave pública, vamos voltar ao exemplo de João e Maria. Se João quer enviar um documento a Maria e

vice-versa, ambos deverão usar suas chaves públicas (únicas e conhecida publicamente) para criptografar o documento e, cada um deles utilizará sua chave privada (única e de conhecimento próprio) para descriptografar o documento, tornando assim mais a criptografia assimétrica mais eficiente e segura em comparação com a criptografia simétrica.

A criptografia assimétrica também pode ser realizada de forma manual ou automática e como exemplos, podemos citar: (a) o padrão de algoritmo de criptografia RSA; (b) o padrão de algoritmo de criptografia DSS e DAS; © o método de troca Diffie-Hellman e por fim (d) os protocolos da pilha TCP/IP TLS e SSL muito utilizados na Internet e, o padrão de criptografia utilizados nos certificados digitais.

Como vantagens do uso da criptografia assimétrica, citamos: (a) a ausência da necessidade de distribuir e compartilhamento a chave secreta e; (b) a possibilidade de realizar a assinatura digital e a autenticação da mensagem o que possibilita tornar a mensagem ou informação autêntica, confiável, passível de verificação, mais segura e não repudiável. Já com relação à desvantagem do uso da criptografia assimétrica, apresenta-se como principal desvantagem a lentidão no processo de cifrar e decifrar o dado. Isto porque, diferente da criptografia simétrica que possui chaves secretas com comprimentos menores, a criptografia assimétrica por sua vez possui chaves secretas com o comprimento mais longo, além de ter uma maior complexidade em seu algoritmo de criptografia.

Neste contexto, podemos em poucas palavras dizer que em comparação entre a criptografia simétrica e assimétrica, a primeira é mais rápida e menos segura, enquanto a segunda é mais lenta, porém, mais segura. Ou seja, o processo de criptografia simétrico é mais simples e rápido de ser realizado, porém, é menos seguro por haver uma única chave secreta que deve ser compartilhada entre as partes envolvidas para cifrar e decifrar a informação. Já no processo de criptografia assimétrica, este por sua vez é mais complexo e lento. Porém, mais seguro devido à utilização de pares de chaves públicas e privadas.

Criptografia Hard Disk

A criptografia hard disk ou também conhecida como criptografia de disco rígido é uma tecnologia de criptografia utilizada para realizar a proteção de dados armazenados em um dispositivo de armazenamento de arquivos como, por exemplo, um disco rígido (HD) ou em um storage de discos de armazenamento, através de algoritmos sofisticados de criptografia.

Uma vez criptografados os dados armazenados, estes não podem ser acessados por qualquer pessoa ou sistema que não possua a chave secreta, permitindo assim uma maior proteção a esses dados com relação a, por exemplo, acesso não autorizado aos dados armazenados.

O conceito por trás da criptografia de disco é muito simples. No momento em que o arquivo de dados é armazenado no disco, ele é automaticamente criptografado através de um software específico a essa função e, no momento que há uma solicitação de acesso e leitura ao mesmo arquivo o software em questão realiza a descryptografia do arquivo de forma automática através do fornecimento da chave secreta.

No geral o algoritmo utilizado para realizar o processo de criptografia e descryptografia dos arquivos é o AES – Advanced Encryption Standard que por sua vez trabalha com o conceito de cifra em blocos com comprimentos que podem ser de 128 ou 256 bits.

Entre os mecanismos de criptografia de disco mais utilizados, destaca-se o BITLOCKER. Trata-se de um recurso de segurança e criptografia desenvolvido pela Microsoft e presente na família de sistemas operacionais MS Windows que permite com que os dados armazenados no disco rígido possam ser criptografados e assim protegidos contra acesso não autorizado.

O Bitlocker utiliza um chip específico denominado de TPM – Trusted Platform Module que está presente no hardware de armazenamento ou, na MotherBoard (placa mãe) do computador. Além do TPM, o Bitlocker pode realizar o bloqueio do processo de inicialização do sistema operacional por meio de uma chave secreta denominada “PIN” que deve ser fornecida pelo usuário do sistema e, pode criar uma chave de recuperação dos dados criptografados no disco, caso o usuário venha a esquecer ou perder sua chave secreta.

RAID

Acrônimo de Redundant Array of Independent Disk ou Matriz Redundante de Discos Independentes é uma tecnologia que permite a combinação de várias unidades de disco físicas em uma única unidade virtual. O principal objetivo do RAID é criar uma redundância de discos, melhorando o desempenho de todo o sistema de armazenamento.

No geral, a tecnologia RAID é utilizada em servidores e computadores de alto desempenho e, tem como função auxiliar na proteção dos dados armazenados. Mas, aqui cabe um lembrete: Não podemos considerar o RAID como um substituto para o procedimento de cópia de segurança ou simplesmente o Backup. Isto porque, caso um arquivo contido em um esquema RAID seja excluído ou substituído, ele não poderá ser restaurado por meio do RAID.

As configurações RAID são conhecidas como matrizes RAID e, essencialmente, trata-se de um conjunto de unidades (discos) de armazenamento sincronizadas para a criação de novas unidades de armazenamento maiores ou múltiplas.

Uma matriz RAID usa vários discos de armazenamento que o sistema operacional visualiza como uma única unidade de disco. Os dados armazenados podem ser duplicados ou distribuídos pela matriz de discos, o que possibilita que sejam preservados em caso de uma falha de uma das unidades de disco que compõem a matriz.

A criação de um esquema de RAID irá depender da finalidade/prioridade que o usuário deseja obter naquele sistema. Essa finalidade/prioridade irá ser de acordo com questões relacionadas à disponibilidade, desempenho ou escalabilidade que se deseja alcançar.

Com relação à configuração de um esquema RAID a mesma poderá ser realizada de duas formas: a primeira é conhecida como distribuição de disco, onde os dados são distribuídos entre os discos pertencentes a matriz RAID e não duplicados. Neste esquema, pode haver perda de dados caso um dos discos falhe. A segunda é conhecida como espelhamento de dados, onde os dados são duplicados nas unidades de disco pertencentes a matriz RAID. Isto permite uma recuperação dos dados caso ocorra uma falha em uma unidade de disco.

No geral, as organizações que armazenam grandes quantidades de dados, criam uma matriz RAID conhecida como “array RAID”. Esse esquema utiliza uma controladora RAID para realizar todo o controle e gerenciamento do “array” e, por se tratar de uma solução robusta e confiável, possui um custo operacional maior se comparada com outras soluções de RAID baseadas em software.

Com relação às arquiteturas que podem ser utilizadas em uma matriz RAID, essas são denominadas de níveis e são implementadas de acordo com o desejo de obter um maior desempenho na leitura, escrita e armazenamento de dados ou na tolerância a falhas durante o armazenamento de dados. Os mais comuns são: (a) RAID 0 – matriz de discos distribuída sem tolerância a falhas – neste nível os dados são distribuídos entre os discos que compõem a matriz RAID sem nenhum tipo de redundância. Em termos de desempenho este nível oferece um melhor desempenho. Mas, em contrapartida, não oferece nenhum tipo de tolerância a falhas. Ou seja, caso uma das unidades de disco que compõe a matriz falhe, todos os dados contidos neste disco serão perdidos; (b) RAID 1 – espelhamento e duplexiç o duplicaç o – este nível fornece um espelhamento dos discos que compõem a matriz RAID proporcionando assim a tolerância a falhas. Mas, em contrapartida, diminui o desempenho das unidades de disco com relação a taxas de gravação dos dados; (c) RAID 5 – paridade distribuída intercalada em blocos – similar ao RAID 0, mas com uma única e principal diferença: a tolerância a falhas; (d) RAID 6 – discos de dados independentes com paridade dupla – semelhante ao RAID 5, porém acrescentado uma unidade de disco para a tolerância a falhas; (e) RAID 10 – faixa de espelhos – a ideia aqui é a criação de vários espelhos de disco (RAID 1) e um esquema RAID 0 para que possa se obter o máximo em desempenho, redundância e tolerância a falhas.

DLP – Data Loss Prevention

Acrônimo de prevenção contra perda de dados, o DLP é um mecanismo utilizado pelas equipes de segurança da informação e segurança cibernética que tem como objetivo detectar e prevenir incidentes relacionados a dados, tais como: violação de dados, extração de dados de forma não autorizada, vazamento de dados, destruição indesejada de dados confidenciais e/ou dados pessoais, dentre outros, servindo assim como uma ferramenta poderosa na proteção de dados e na conformidade de leis e

regulamentações tais como: a LGPD e a GDPR que são leis específicas destinadas a proteção e privacidade de dados pessoais.

O termo DLP pode ser compreendido como à defesa das organizações contra perda de dados e prevenção de vazamento de dados. Cabe aqui diferenciarmos os termos “perda” e “vazamento” de dados. A perda de dados, refere-se a um evento ou incidente de segurança no qual dados importantes são perdidos em decorrência, por exemplo, de um ataque de um ransomware ou a exclusão acidental ou não de dados em um sistema de gerenciamento de banco de dados. Já o vazamento de dados, refere-se, por exemplo, a distribuição ou exposição de dados importantes, confidenciais ou dados pessoais de forma não autorizada na internet ou em qualquer outro lugar. Neste contexto, é importante ressaltar que a prevenção de perda de dados concentra-se na prevenção da transferência ilícita de dados fora dos limites organizacionais.

No geral, as organizações utilizam um sistema DLP para alcançar vários objetivos de segurança, dos quais destacam-se: (a) a proteção de dados e informações pessoais; (b) o cumprimento de leis e regulações referentes a proteção e privacidade de dados pessoais; © a proteção da propriedade intelectual crítica para a organização; (d) a proteção em ambientes BYOD (ambientes de trabalho remoto no qual o colaborador utiliza seus dispositivos computacionais pessoais para realizar o trabalho remoto) e por fim (f) a proteção de dados em sistemas de nuvem (cloud).

Com relação às causas mais comuns de vazamento de dados, podemos citar: (a) ameaças internas – no qual um colaborador interno de forma intencional ou não, promove a exposição ou tenta mover os dados para fora do ambiente interno da organização; (b) extrusão por invasores – no qual um invasor ou criminoso cibernético por meio de um ataque cibernético, baseado em técnicas tais como: phishing, malware, sql injection, engenharia social, dentre outras, invade um sistema ou infraestrutura de TI da organização e consegue obter para si dados importantes e/ou confidenciais; © exposição de dados não intencional ou negligente – neste tipo o vazamento de dados ocorre por meio de colaboradores que perderam dados importantes e/ou confidenciais em público ou fornecem de forma aberta acessos aos dados importantes e/ou confidenciais pela internet, não obedecendo às políticas de segurança da informação, segurança cibernética ou de proteção e privacidade de dados de sua organização.

Por fim, é comum o uso de um sistema DLP em conjunto com outros sistemas/mecanismos de segurança tais como os sistemas de detecção de intrusão (IDS) ou sistemas de prevenção a intrusão (IPS), além dos tradicionais sistemas de Firewall, Antivírus, Gestão de Identidade e Acesso, por exemplo.

É importante dizer que, seja qual for o sistema DLP escolhido pela organização, este deverá ter como principais funções: (a) o monitoramento em tempo real de todos os acessos realizados aos sistemas de gerenciamento de banco de dados, sistemas, aplicativos, etc., incluindo o registro de informações tais como: qual dado foi acessado, que tipo de acesso foi realizado, quem ou qual área acessou o dado, data e hora do acesso, tempo de utilização do dado, para onde o dado foi e assim por diante; (b) bloqueio automático de ações realizadas no dado que violem as políticas de segurança; © detecção mitigação em tempo real de ameaças e, por fim (d) funções e funcionalidades que permitam a auditoria sobre todas as operações realizadas nos dados para fins de conformidade perante leis e regulamentações vigentes e/ou a realização de análise forense para investigação e resolução de incidentes de perda, violação de acesso ou vazamento de dados.

Conteúdo Bônus

Para aprender um pouco mais sobre criptografia e conhecer a história de Alan Turing, indico:

- Filme: O Jogo da Imitação.
- Como funciona o código nazista Enigma?
Disponível no YouTube, em Canal History Brasil.

Referência Bibliográfica

FONTES, E. **Praticando a segurança da informação.** – 2ªEd. Rio de Janeiro. Brasport, 2008.

HARRIS, Shon. **CISSP All-in-one, 3. ed.** Nova York, McGraw Hill, 2004.

KIM, David; SOLOMON, Michael. **Fundamentos de Segurança de Sistemas de Informação** – 1.ed. São Paulo; LTC Exatas Didática, 2014.

LASTRE, H. M. M., ALBAGLI, S. (Org.). **Informação e globalização na era do conhecimento.** Rio de Janeiro: Campus, 1999. 318p.

LYRA, M. R. **Segurança e Auditoria em Sistemas de Informação.** Rio de Janeiro: Ciência Moderna, 2008.

MACHADO, Felipe R. Nery. **Segurança da Informação – Princípios e controle de ameaças – 1.ed.** Rio de Janeiro; Editora Érica, 2014.

SÊMOLA, M. **Gestão da Segurança da Informação - Uma Visão Executiva - 2 ed.** São Paulo: Elsevier, 2014.

STALLINGS, W. **Criptografia e Segurança de Redes.** 4 ed. São Paulo: Pearson, 2008.

STALLINGS, Willian; BROWN Lawrie. **Segurança de Computadores – Princípios e Práticas.** 2.ed. São Paulo; Elsevier, 2017.

TANENBAUM, Andrew. S. **Redes de Computadores.** 4ª ed. Rio de Janeiro: Editora Campus (Elsevier), 2011.